

Scenario 01 — PortPilot Maritime

Trainee handbook

🕒 Estimated time: **2 hours** · 🎯 Level: **Intermediate** · 🌐 Sector: **Maritime**

Scenario brief

You are the new cybersecurity officer at **Larnaca Port Authority**. Your team has just finished onboarding **PortPilot v0.9.2**, a small web application written in-house to track vessel arrivals and cargo manifests.

Before the application is rolled out fleet-wide, the board has asked you to perform a full security review using the **CyberFort** compliance platform and to prepare a **Cyber Resilience Act (CRA)** readiness report.

You have:

- A virtual machine running CyberFort (`https://<VM1-IP>:5173`).
 - A virtual machine hosting PortPilot in Docker (`http://<VM2-IP>:8080`). You also have shell access to VM2.
 - CyberFort credentials issued by your instructor.
 - A copy of the PortPilot source code in `/srv/portpilot/app/` on VM2.
-

Learning outcomes

By the end of this scenario you will be able to:

1. Register a product in CyberFort and prepare it for scanning.
 2. Run an **Nmap** network scan and interpret the results.
 3. Run an **OWASP ZAP** dynamic scan against a web application.
 4. Run a **Semgrep** SAST scan against application source code.
 5. Run an **OSV** dependency scan against a `requirements.txt`.
 6. Map findings to **CRA Annex I** essential cybersecurity requirements.
 7. Create entries in the **Risk Register** and assign mitigations.
 8. Export a CRA readiness PDF report.
-

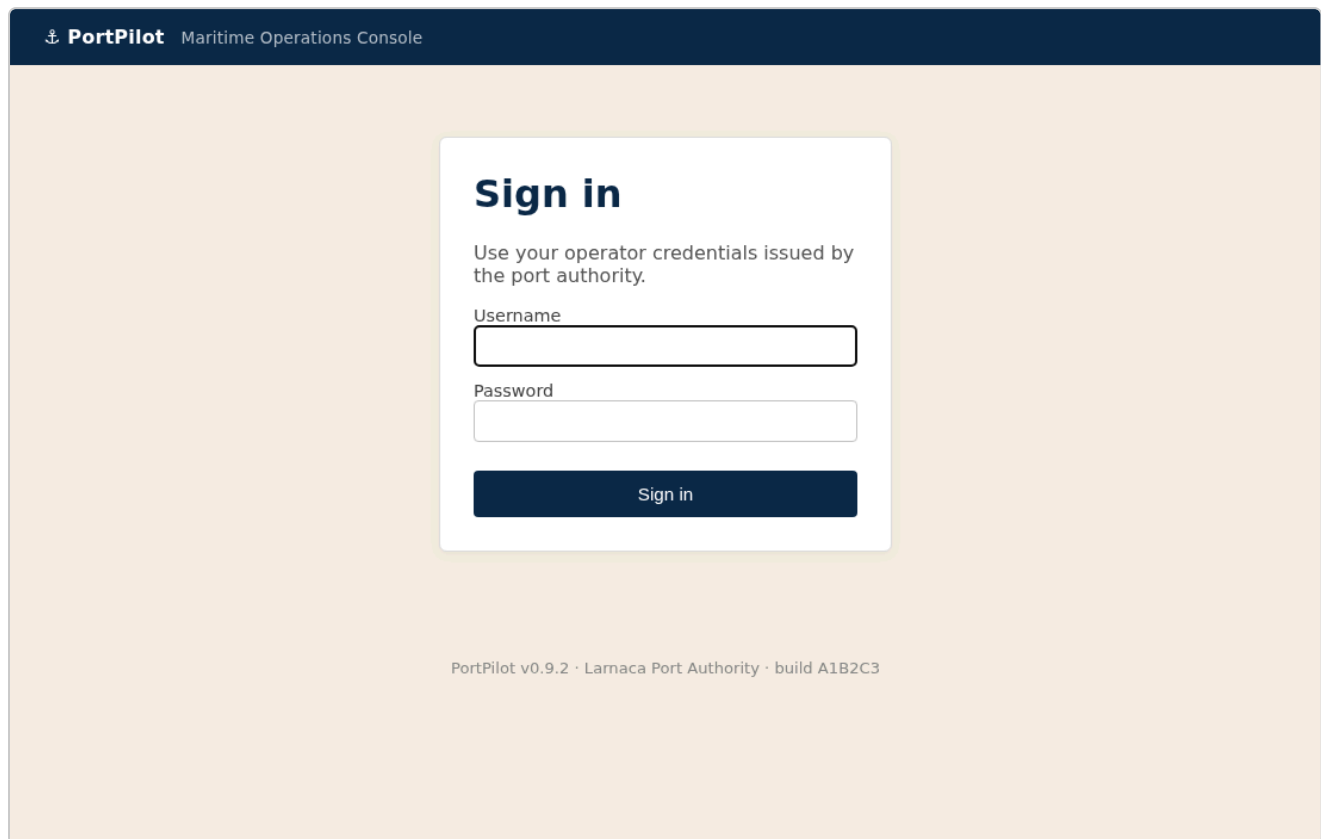
Step 0 — Verify the lab is up

On VM2:

```
cd /srv/portpilot
docker compose ps
```

You should see two healthy containers, `portpilot_app` and `portpilot_db`.

Open `http://<VM2-IP>:8080/login` in a browser. You should land on the PortPilot sign-in page:



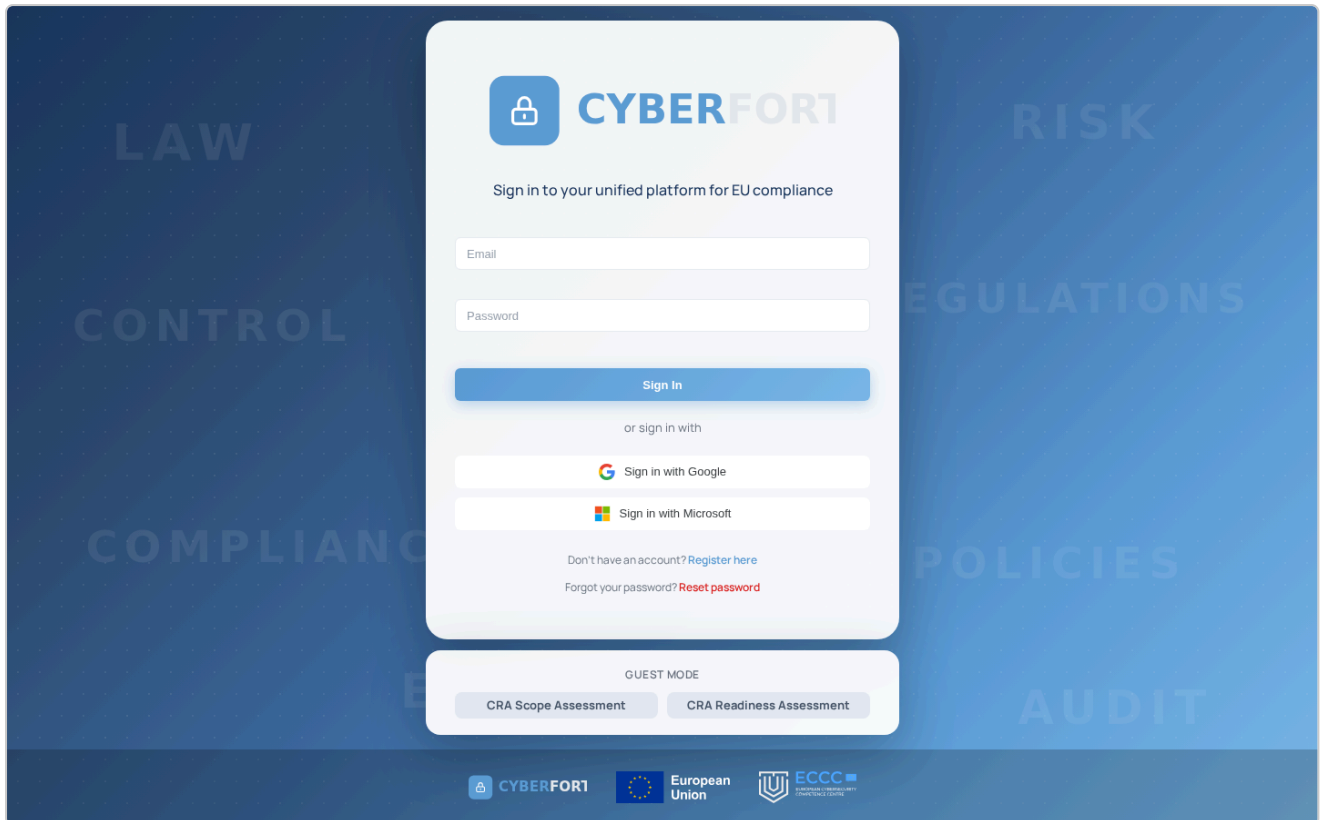
The screenshot shows the PortPilot Maritime Operations Console sign-in page. The page has a dark blue header with the PortPilot logo and the text "Maritime Operations Console". The main content area is light beige and contains a white sign-in form. The form has a title "Sign in", a subtitle "Use your operator credentials issued by the port authority.", and two input fields labeled "Username" and "Password". Below the input fields is a dark blue button labeled "Sign in". At the bottom of the page, there is a footer that reads "PortPilot v0.9.2 · Larnaca Port Authority · build A1B2C3".



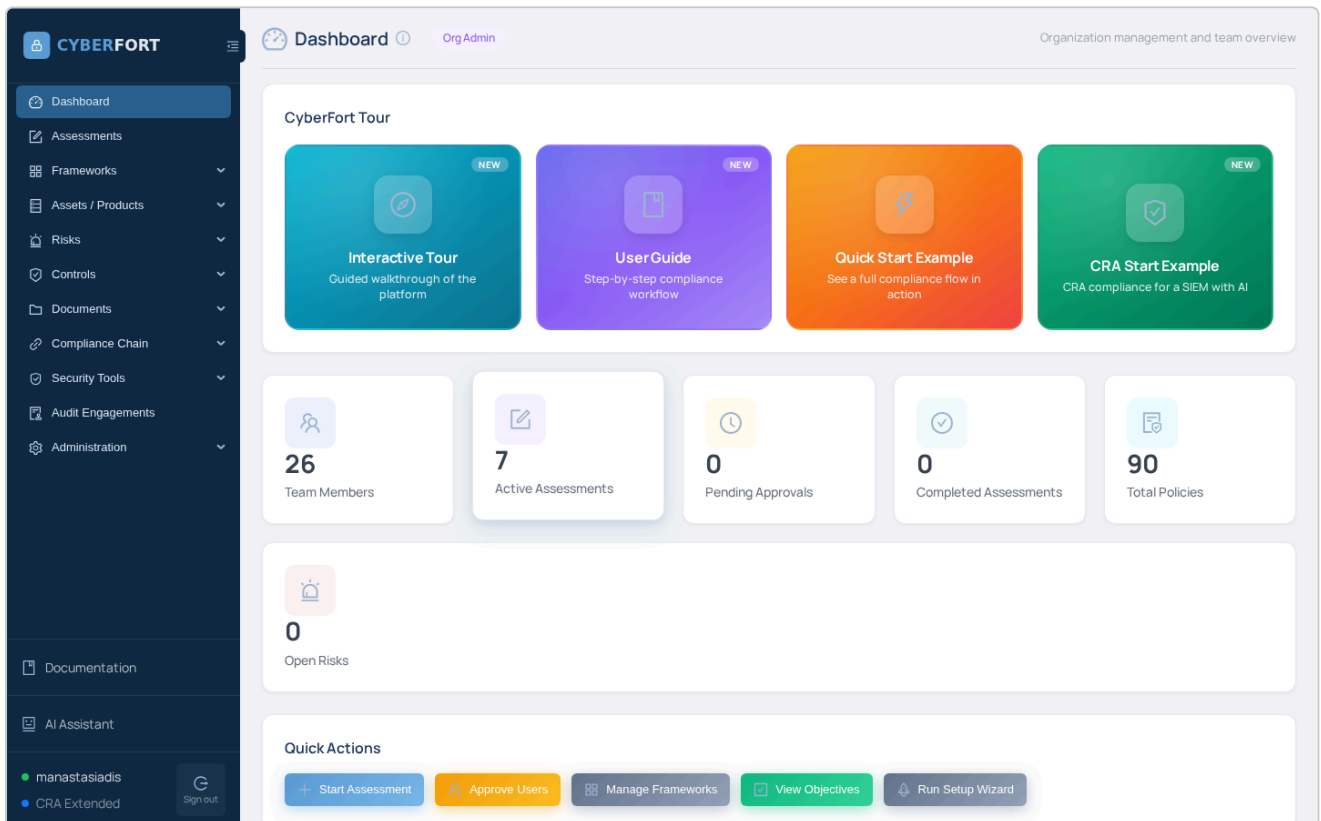
Do **not** try to sign in yet. We will let CyberFort do the discovery for us.

Platform access

CyberFort runs on VM1 in a standard cyber-range deployment. For sessions that use the **hosted reference instance** at `https://access.cyber-fort.eu/login`, sign in with the credentials issued by your instructor:



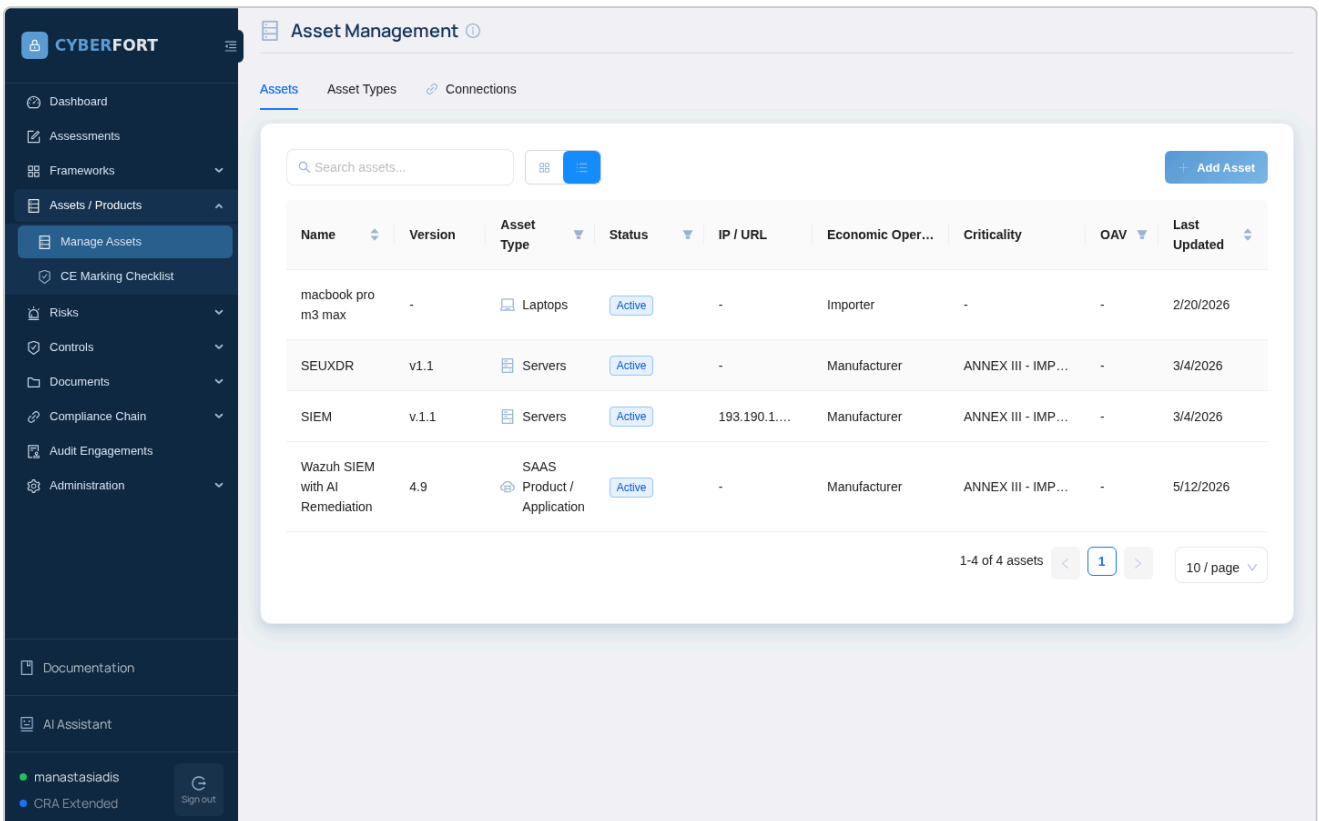
After signing in you land on the operations dashboard. The sidebar holds every module you will use: **Assessments, Frameworks, Assets / Products, Risks, Security Tools**, and the **AI Assistant**.



 The hosted reference instance cannot reach a private cyber-range subnet, so the scanner integrations cannot actively scan your VM2 from there. The walkthrough below shows the **exact UI steps** for each scan — and where the scanner cannot reach your target, you **replicate** the finding by adding it manually to the Risk Register (the platform handles both flows the same way once a finding exists).

Step 1 — Register PortPilot as a product in CyberFort

1. From the left sidebar, expand **Assets / Products** and click **Manage Assets**. The page lists every asset / product already registered for your organisation.



The screenshot displays the CyberFort Asset Management interface. On the left is a dark sidebar with the CyberFort logo and a menu including Dashboard, Assessments, Frameworks, Assets / Products (expanded), Manage Assets (selected), CE Marking Checklist, Risks, Controls, Documents, Compliance Chain, Audit Engagements, and Administration. The main content area is titled 'Asset Management' and has tabs for Assets, Asset Types, and Connections. The Assets tab is active, showing a search bar, a '+ Add Asset' button, and a table of assets. The table has columns for Name, Version, Asset Type, Status, IP / URL, Economic Oper..., Criticality, OAV, and Last Updated. Four assets are listed: 'macbook pro m3 max' (Laptops, Active, 2/20/2026), 'SEUXDR' (Servers, Active, 3/4/2026), 'SIEM' (Servers, Active, 3/4/2026), and 'Wazuh SIEM with AI Remediation' (SAAS Product / Application, Active, 5/12/2026). At the bottom right of the table, it shows '1-4 of 4 assets' and a pagination control for '10 / page'.

Name	Version	Asset Type	Status	IP / URL	Economic Oper...	Criticality	OAV	Last Updated
macbook pro m3 max	-	Laptops	Active	-	Importer	-	-	2/20/2026
SEUXDR	v1.1	Servers	Active	-	Manufacturer	ANNEX III - IMP...	-	3/4/2026
SIEM	v.1.1	Servers	Active	193.190.1...	Manufacturer	ANNEX III - IMP...	-	3/4/2026
Wazuh SIEM with AI Remediation	4.9	SAAS Product / Application	Active	-	Manufacturer	ANNEX III - IMP...	-	5/12/2026

2. Click the green **+ Add Asset** button (top right). A modal opens with the *Details* tab pre-selected.

Asset Management

Add New Asset

Details | CIA Matrix

Asset Name * Version

Asset Type * Status

Economic Operator Criticality

License IP Address / IP Range / URL

Justification

Description

SBOM (Software Bill of Materials)

3. Fill in the fields: * **Asset Name:** PortPilot * **Version:** 0.9.2 * **Asset Type:** SAAS Product / Application (or Application if your tenant uses that label) * **Status:** Active * **Economic Operator:** Manufacturer (you are auditing the product on behalf of the manufacturing entity) * **Criticality:** ANNEX III – IMPORTANT PRODUCTS WITH DIGITAL ELEMENTS (the app handles cargo manifests subject to customs oversight) * **IP Address / URL:** the IP of your PortPilot host (e.g. 10.10.20.30) * **Description:** "In-house Flask vessel and cargo manifest manager for Larnaca port operations."

Asset Management

Add New Asset

Details | CIA Matrix

Asset Name * Version

Asset Type * Status

Economic Operator Criticality

License IP Address / IP Range / URL

Justification

Description

SBOM (Software Bill of Materials)

4. Click **Save**. The modal closes and PortPilot appears in the asset list.

The screenshot shows the CyberFort Asset Management interface. The left sidebar contains navigation links: Dashboard, Assessments, Frameworks, Assets / Products (expanded), Manage Assets (selected), CE Marking Checklist, Risks, Controls, Documents, Compliance Chain, Audit Engagements, and Administration. The main content area is titled 'Asset Management' and has tabs for Assets, Asset Types, and Connections. The Assets tab is active, displaying a table of assets. The table has columns: Name, Version, Asset Type, Status, IP / URL, Economic Oper..., Criticality, OAV, and Last Updated. The assets listed are: macbook pro m3 max (Laptops, Active, 2/20/2026), PortPilot (SAAS Product / Application, Active, 10.10.20.30, 5/13/2026), SEUXDR (Servers, Active, 3/4/2026), SIEM (Servers, Active, 193.190.1..., 3/4/2026), and Wazuh SIEM with AI Remediation (SAAS Product / Application, Active, 5/12/2026). At the bottom right of the table, it shows '1-5 of 5 assets' and a pagination control with '1' selected and '10 / page'.

Name	Version	Asset Type	Status	IP / URL	Economic Oper...	Criticality	OAV	Last Updated
macbook pro m3 max	-	Laptops	Active	-	Importer	-	-	2/20/2026
PortPilot	0.9.2	SAAS Product / Application	Active	10.10.20.30	Manufacturer	-	-	5/13/2026
SEUXDR	v1.1	Servers	Active	-	Manufacturer	ANNEX III - IMP...	-	3/4/2026
SIEM	v.1.1	Servers	Active	193.190.1...	Manufacturer	ANNEX III - IMP...	-	3/4/2026
Wazuh SIEM with AI Remediation	4.9	SAAS Product / Application	Active	-	Manufacturer	ANNEX III - IMP...	-	5/12/2026

Step 2 — Run an Nmap discovery scan

The first question a CRA-aware auditor asks is "what is even exposed?". CyberFort's Nmap integration is under **Security Tools** → **Security Scanners** (the *Network Vulnerability* tab).

1. Expand **Security Tools** in the sidebar and click **Security Scanners**.
2. Choose **Scan Type** = **Basic Scan - Top 1000 ports**.
3. Set **Target** to the IP of the PortPilot host (e.g. **10.10.20.30**).
4. Click **Run Scan**. The scan takes ~1 minute. (If you are using the hosted reference instance and it cannot reach your private target, see the note below the screenshot.)

CYBERFORT

Dashboard
Assessments
Frameworks
Assets / Products
Risks
Controls
Documents
Compliance Chain
Audit Engagements
Administration

Documentation
AI Assistant
manastasiadis
CRA Extended
Sign out

Security Scanners

Network Vulnerability
Application Vulnerability

Scanner Guide

Scan Configuration

Scan Type

Basic Scan - Top 1000 ports

Target

IP address, domain, or network range

☒ Enter Custom IP/Domain
☐ Select from Assets

Run Scan

Clear

Schedule

Scan Results 12

Search history...

Timestamp

Scan Type

Status

Severity

Duration (s)

User

Organization

Acti

>

Apr 25, 2026, 09:07:48 AM

basic

COMPLETED

INFO

39.27

nkekatos@clone-system...

Clone Systems

>

Apr 25, 2026, 09:06:38 AM

aggressive

COMPLETED

INFO

0.67

nkekatos@clone-system...

Clone Systems

>

Apr 25, 2026, 09:06:02 AM

basic

COMPLETED

INFO

0.45

nkekatos@clone-system...

Clone Systems

>

Mar 14, 2026, 11:29:25 AM

basic

COMPLETED

INFO

20.65

nkekatos@clone-system...

Clone Systems

>

Feb 26, 2026, 01:56:22 PM

fast

COMPLETED

INFO

19.08

superadmin@clone-syst...

Clone Systems

>

Feb 26, 2026, 01:43:07 PM

basic

COMPLETED

INFO

23.15

superadmin@clone-syst...

Clone Systems

>

Jan 28, 2026, 08:06:20 AM

os

COMPLETED

N/A

13.73

superadmin@clone-syst...

Clone Systems

>

Nov 24, 2025, 09:36:04 AM

basic

COMPLETED

N/A

16.22

nmiaritis@clone-system...

Clone Systems

>

Nov 21, 2025, 07:57:09 PM

all_ports

COMPLETED

N/A

225.05

superadmin@clone-syst...

Clone Systems

>

Nov 21, 2025, 08:25:52 AM

basic

COMPLETED

N/A

5.47

nmiaritis@clone-system...

Clone Systems

1-10 of 12 scans

<

1

2

>

10 / page

Go to

Page

When the scan completes you should see at least:

Port	Service	Notes
8080	http	PortPilot web UI
5432	postgresql	PostgreSQL 13 — unexpected

Finding #1 — Exposed database. PostgreSQL should never be reachable from outside the application host. CRA Annex I objectives **3a** (secure by default configuration) and **3h** (limit attack surfaces).

Replicate the finding in the Risk Register

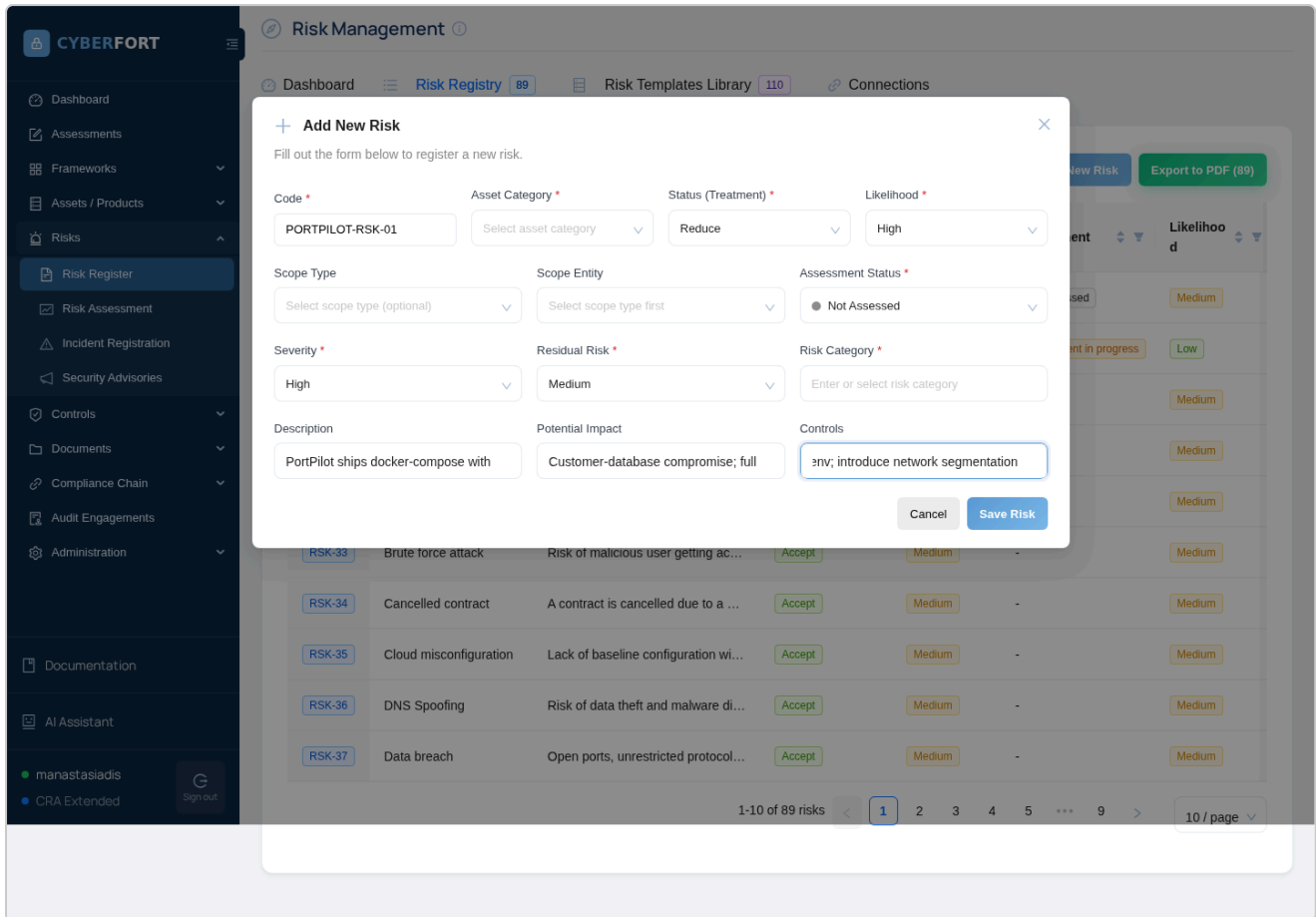
If the scanner couldn't actually reach your target (the network is private), open **Risks** → **Risk Register** and click **Add New Risk** (top-right or under *Quick Actions*).

The screenshot shows the CYBERFORT Risk Management interface. A sidebar on the left contains navigation links: Dashboard, Assessments, Frameworks, Assets / Products, Risks, Risk Register, Risk Assessment, Incident Registration, Security Advisories, Controls, Documents, Compliance Chain, Audit Engagements, and Administration. The main area displays the 'Risk Register' with a table of risks. A modal window titled 'Add New Risk' is open, prompting the user to fill out a form to register a new risk. The form includes fields for Code, Asset Category, Status (Treatment), Likelihood, Scope Type, Scope Entity, Assessment Status, Severity, Residual Risk, Risk Category, Description, Potential Impact, and Controls. The background table shows existing risks with columns for ID, Description, Risk, Status, Likelihood, and Impact.

ID	Description	Risk	Status	Likelihood	Impact
RSK-33	Brute force attack	Risk of malicious user getting access to the system	Accept	Medium	-
RSK-34	Cancelled contract	A contract is cancelled due to a security issue	Accept	Medium	-
RSK-35	Cloud misconfiguration	Lack of baseline configuration with cloud services	Accept	Medium	-
RSK-36	DNS Spoofing	Risk of data theft and malware distribution	Accept	Medium	-
RSK-37	Data breach	Open ports, unrestricted protocols, and weak passwords	Accept	Medium	-

Fill the form to record the exposed-database finding:

- **Code:** PORTPILOT-RSK-01
- **Status (Treatment):** Reduce
- **Likelihood:** High · **Severity:** High · **Residual Risk:** Medium
- **Risk Category:** Network / Infrastructure
- **Description:** "PortPilot ships docker-compose with PostgreSQL bound to 0.0.0.0:5432 and the default weak password 'PortPilot2024!'. Discovered via Nmap. CRA Annex I objectives 3a (secure by default), 3h (limit attack surfaces)."
- **Potential Impact:** "Customer-database compromise; full read/write to cargo manifests; GDPR Article 32 violation."
- **Controls:** "Remove ports:5432 mapping; rotate to strong password loaded from env; introduce network segmentation."



Click **Save Risk**. The new entry appears in the Risk Registry tab. We will come back to assign a mitigation owner once the full picture is captured.

Step 3 — Run an OWASP ZAP dynamic scan

OWASP ZAP lives in **Security Tools** → **Security Scanners** under the *Application Vulnerability* tab (the same page as Nmap; switch tabs at the top).

1. Open **Security Tools** → **Security Scanners** and switch to the **Application Vulnerability** tab.
2. Target URL: `http://<VM2-IP>:8080`
3. Scan type: `Active scan` (full).
4. Click **Run Scan**. This takes 3–6 minutes.

While ZAP is running, do not refresh the page repeatedly — it is enumerating endpoints in the background. When the run completes, you should see several alerts. The ones to focus on:

3a. SQL Injection on `/login`

ZAP will tag this as **SQL Injection – Authentication Bypass** with risk `High`.

Verify it yourself in a browser:

1. Open `http://<VM2-IP>:8080/login`.
2. In **Username** type: `admin' OR '1'='1' --`
3. In **Password** type anything, e.g. `x`.

Sign in

Use your operator credentials issued by the port authority.

Username

admin' OR '1'='1' --

Password

Sign in

4. Click **Sign in**.

You should land on the dashboard authenticated as **admin (admin)** — note the user pill in the top-right of the header:

Arrivals

Next vessels expected at Larnaca anchorage.

IMO	Name	Flag	Status	ETA
IMO9333888	MV Limassol Pride	Cyprus	Departed	2026-05-10 10:06:09.286154
IMO9666777	MV Adriatic Sun	Italy	Berthed	2026-05-11 02:06:09.286154
IMO9123456	MV Larnaca Dawn	Greece	Berthed	2026-05-11 08:06:09.286154
IMO9876543	MV Aegean Star	Cyprus	Inbound	2026-05-11 16:06:09.286154
IMO9555111	MV Helios Wave	Malta	Inbound	2026-05-12 04:06:09.286154
IMO9777222	MV Black Sea Lily	Romania	Inbound	2026-05-12 10:06:09.286154
IMO9888999	MV Carpathian	Romania	Inbound	2026-05-13 10:06:09.286154
IMO9444555	MV Polaris	Panama	Inbound	2026-05-14 10:06:09.286154

🔴 **Finding #2 — Authentication bypass via SQL injection.** This is a critical break of CRA Annex I objective **3b** (protection from unauthorised access) and objective **2** (no known exploitable vulnerabilities at ship time).

3b. Reflected XSS on `/vessels`

ZAP will tag this as **Cross Site Scripting (Reflected)** with risk **Medium**.

Verify:

1. Still logged in, navigate to `http://<VM2-IP>:8080/vessels?q=<script>alert(1)</script>` — a JavaScript alert box pops up immediately on page load (proving JS execution).
2. For a *visible* demonstration that does not depend on the dialog, try a pure-HTML payload that the page renders unsanitised, e.g. `?q=<span style="background:red;color:white;padding:10px">XSS</span>`:

PortPilot Maritime Operations Console

Dashboard Vessels My Manifests admin (admin) Logout

Search by vessel name or IMO Search

Results for:

🔴 **XSS — user input rendered as HTML, no sanitisation**

IMO	Name	Flag	Status	ETA
No vessels match your search.				

PortPilot v0.9.2 · Lamaca Port Authority · build A1B2C3

🔴 **Finding #3 — Reflected XSS in vessel search.** CRA Annex I objective **3d** (integrity of data/configuration) and objective **2** (no known exploitable vulnerabilities).

3c. Missing authentication on `/admin/manifests`

ZAP's spider will follow the link or you may need to add the URL manually under **Sites** → **Add URL**. Once scanned, ZAP flags **Authentication Required – bypass**.

Verify in a private/incognito window (no session cookie):

1. Open `http://<VM2-IP>:8080/admin/manifests`
2. The page loads and shows every manifest in the database — including rows marked **CLASSIFIED** (row 4 — *strategic fuel reserve for partner network*) and **CONFIDENTIAL** (row 6 — *offshore wind*)

installation components):

All manifests (admin view)

Internal — confidential cargo notes included.

#	Vessel	Cargo	Tonnes	Consignee	Notes
1	MV Aegean Star	Containers (20ft)	4200.5	Cyprus Importers Ltd	Standard cargo, no notes.
2	MV Larnaca Dawn	Refrigerated produce	980.0	Mediterranean Foods SA	Temperature must remain below 4°C during discharge.
3	MV Helios Wave	Bulk grain	12500.0	Helios Agri-Cooperative	Customs pre-clearance attached.
4	MV Black Sea Lily	Liquid bulk (diesel)	8800.0	EximProd Engineering S.A.	CLASSIFIED: strategic fuel reserve for partner network.
5	MV Limassol Pride	Containers (40ft)	3650.2	Limassol Logistics Hub	Routine outbound shipment.
6	MV Polaris	Project cargo (turbine)	420.0	EU Energy Partners	CONFIDENTIAL: offshore wind installation components.
7	MV Adriatic Sun	Containers (mixed)	5400.8	Adriatic Trade House	Customer requests after-hours discharge.
8	MV Carpathian	Vehicles (ro-ro)	1850.0	Romanian Auto Imports	Standard cargo, no notes.

 **Finding #4 — Confidentiality breach via broken access control.** CRA Annex I objectives **3b** (protection from unauthorised access) and **3c** (confidentiality of processed data); also relevant to NIS2 incident-reporting obligations if this were in production.

For each of the three ZAP findings, follow the same **Add New Risk** flow you used for the Nmap finding in Step 2 (Risks → Risk Register → *Add New Risk*). Use the scoring below; each row is one new entry in the Risk Register:

Finding	Likelihood	Impact	Linked CRA objective (Annex I)
SQL injection login bypass	High	High	3b (protection from unauthorised access) · 2 (no known exploitable vulnerabilities)
Reflected XSS on /vessels	Medium	Medium	3d (integrity of data/configuration) · 2
Broken access on /admin/manifests	High	High	3b (protection from unauthorised access) · 3c (confidentiality)

Step 4 — Run a Semgrep SAST scan

CyberFort's Semgrep integration lives at **Security Tools** → **Code Analysis**. It reads your application source code and finds vulnerabilities the running app cannot reveal — including secrets and dangerous patterns that are not yet reachable.

1. On VM2, package the source so CyberFort can read it:

```
cd /srv/portpilot  
zip -r /tmp/portpilot-src.zip app/
```

2. In CyberFort, expand **Security Tools** in the sidebar and click **Code Analysis**.
3. Drop or browse to the ZIP under *Source Code* → *Click to select a ZIP file*. Pick the **Analysis Mode** (**Use Default** or **Fast Results**).
4. Click **Run Scan**.

CYBERFORT

Dashboard

Assessments

Frameworks

Assets / Products

Risks

Controls

Documents

Compliance Chain

Audit Engagements

Administration

Documentation

AI Assistant

manastasiadis

CRA Extended

Sign out

Code Analysis

Scanner Guide

Scan Configuration

Configuration *

auto

Analysis Mode

LLM Analysis

Fast Results

Source Code

Upload ZIP File

GitHub Repository

Click to select a ZIP file

Upload a ZIP file containing source code for security analysis

Run Scan

Clear

Schedule

Scan Results 99+

Search history...

	Timestamp	Scan Type	Status	Severity	Duration (s)	User	Organization	Acti
>	May 13, 2026, 08:59:07 AM	basic	FAILED	N/A	0.00	manastasiadis@clone-s...	Clone Systems	
>	May 13, 2026, 07:59:07 AM	basic	FAILED	N/A	0.00	manastasiadis@clone-s...	Clone Systems	
>	May 13, 2026, 06:59:07 AM	basic	FAILED	N/A	0.00	manastasiadis@clone-s...	Clone Systems	
>	May 13, 2026, 05:59:07 AM	basic	FAILED	N/A	0.00	manastasiadis@clone-s...	Clone Systems	
>	May 13, 2026, 04:59:07 AM	basic	FAILED	N/A	0.00	manastasiadis@clone-s...	Clone Systems	
>	May 13, 2026, 03:59:07 AM	basic	FAILED	N/A	0.00	manastasiadis@clone-s...	Clone Systems	
>	May 13, 2026, 02:59:07 AM	basic	FAILED	N/A	0.00	manastasiadis@clone-s...	Clone Systems	
>	May 13, 2026, 01:59:07 AM	basic	FAILED	N/A	0.00	manastasiadis@clone-s...	Clone Systems	
>	May 13, 2026, 12:59:07 AM	basic	FAILED	N/A	0.00	manastasiadis@clone-s...	Clone Systems	
>	May 12, 2026, 11:59:07 PM	basic	FAILED	N/A	0.00	manastasiadis@clone-s...	Clone Systems	

1-10 of 100 scans

12345...10

10 / page

Go to

Page

Expected findings:

Severity	Rule	File
High	hardcoded-password	app/portpilot/config.py

Severity	Rule	File
High	<code>python.flask.security.audit.sqli</code>	<code>app/portpilot/app.py</code>
Medium	<code>flask-debug-true</code>	<code>app/portpilot/app.py</code>
Medium	<code>mark-safe-with-user-input</code>	<code>app/portpilot/app.py</code>

 **Finding #5 — Hardcoded secrets in source code.** `config.py` contains a database password and an API key in plaintext. CRA Annex I objective **3d** (integrity protection) — anyone who reads the source can manipulate stored data.

Open the Risk Register and click **Add New Risk** to file the hardcoded-password finding:

- **Title:** `Hardcoded credentials in application source`
- **Likelihood:** `Medium` (depends on who can read the repo)
- **Severity:** `High`
- **Linked objective:** CRA → Annex I → **3d** (*integrity of data, commands and configuration*) — anyone who can read the repo can read every secret and rewrite production data

Step 5 — Run an OSV dependency scan

The CRA puts the burden of **known-exploited vulnerabilities in third-party components** squarely on the manufacturer. CyberFort's OSV integration lives at **Security Tools** → **Dependency Check**.

1. Expand **Security Tools** in the sidebar and click **Dependency Check**.
2. Upload the same ZIP you used for Semgrep — or just the `app/requirements.txt` — under *Source Code* → *Click to select a ZIP file*. Pick the **Scan Control** mode (`LLM Analysis` for richer remediation suggestions, `Fast Results` for a quicker pass).
3. Click **Run Scan**.

- Dashboard
- Assessments
- Frameworks
- Assets / Products
- Risks
- Controls
- Documents
- Compliance Chain
- Audit Engagements
- Administration

Documentation

AI Assistant

manastasiadis

CRA Extended

Sign out

Dependency Analysis

Scanner Guide

Source Code

Upload ZIP File

GitHub Repository

Click to select a ZIP file

Upload a ZIP file containing source code to scan for dependency vulnerabilities

Scan Control

LLM Analysis

Fast Results

Run Scan

Clear

Schedule

Scan Results

99+

Search history...

Grid

Table

	Timestamp	Scan Type	Status	Severity	Duration (s)	User	Organization	Action
>	May 13, 2026, 08:59:07 AM	basic	FAILED	N/A	0.00	manastasiadis@clone-s...	Clone Systems	
>	May 13, 2026, 08:59:07 AM	basic	FAILED	N/A	0.00	manastasiadis@clone-s...	Clone Systems	
>	May 13, 2026, 07:59:07 AM	basic	FAILED	N/A	0.00	manastasiadis@clone-s...	Clone Systems	
>	May 13, 2026, 07:59:07 AM	basic	FAILED	N/A	0.00	manastasiadis@clone-s...	Clone Systems	
>	May 13, 2026, 06:59:07 AM	basic	FAILED	N/A	0.00	manastasiadis@clone-s...	Clone Systems	
>	May 13, 2026, 06:59:07 AM	basic	FAILED	N/A	0.00	manastasiadis@clone-s...	Clone Systems	
>	May 13, 2026, 05:59:07 AM	basic	FAILED	N/A	0.00	manastasiadis@clone-s...	Clone Systems	
>	May 13, 2026, 05:59:07 AM	basic	FAILED	N/A	0.00	manastasiadis@clone-s...	Clone Systems	
>	May 13, 2026, 04:59:07 AM	basic	FAILED	N/A	0.00	manastasiadis@clone-s...	Clone Systems	
>	May 13, 2026, 04:59:07 AM	basic	FAILED	N/A	0.00	manastasiadis@clone-s...	Clone Systems	

1-10 of 100 scans

1

2

3

4

5

...

10

10 / page

Go to

Page

You should see at least these advisories:

Package	Version	Advisory ID(s)
Flask	2.0.1	GHSA-m2qf-hxjv-5gpg (session fixation)

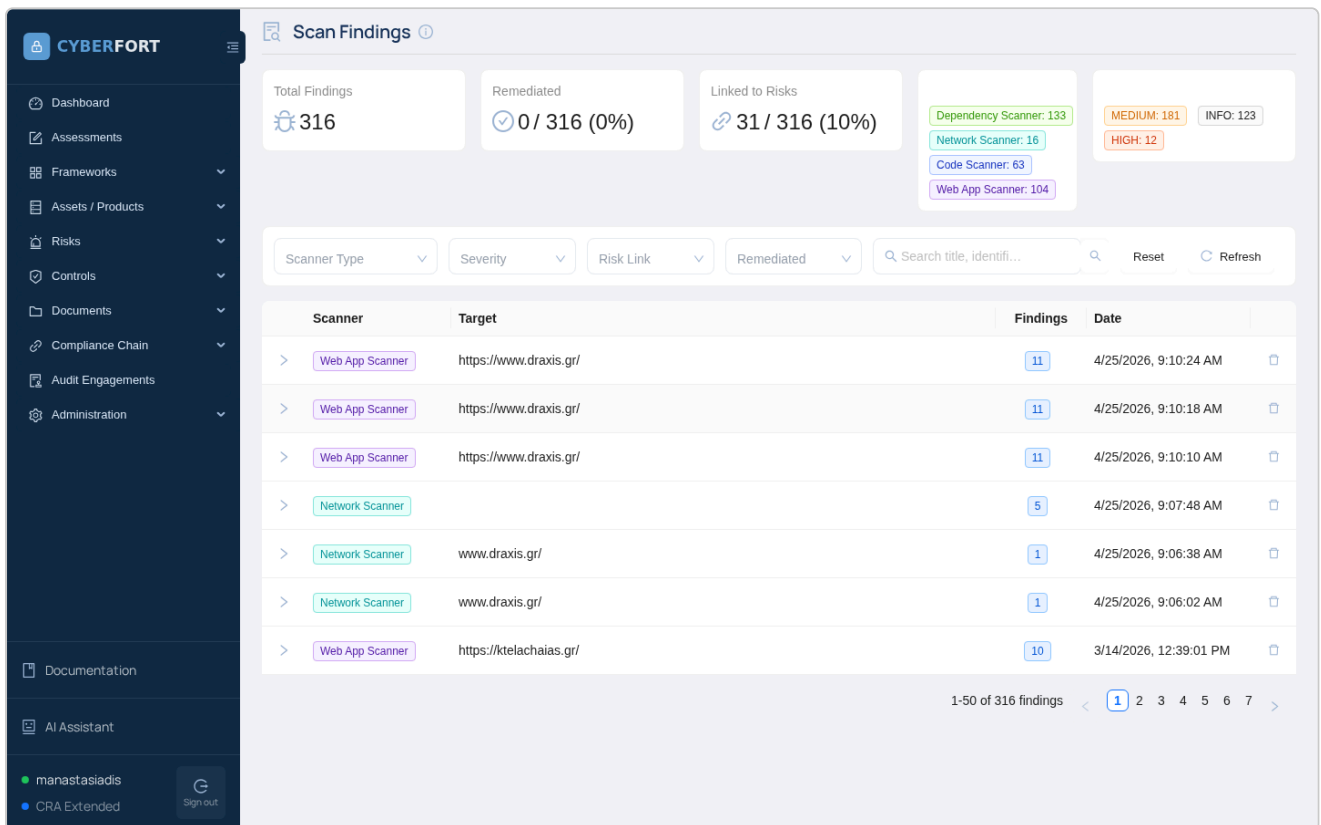
Package	Version	Advisory ID(s)
Werkzeug	2.0.1	GHSA-px8h-6qyv-m22q, GHSA-2g68-c3qc-8985, GHSA-xg9f-g7g7-2323
Jinja2	3.0.0	GHSA-h5c8-rqwp-cp95, GHSA-h75v-3vvj-5mfj
requests	2.25.0	GHSA-j8r2-6x86-q33q (Proxy-Auth leak)

 **Finding #6 — Multiple high-severity advisories on transitive dependencies.** Links to CRA Vulnerability Handling objective **1** (*identify and document components, SBOM*) and Annex I **2** (*delivered without known exploitable vulnerabilities*).

Convert the most severe (Werkzeug GHSA-2g68-c3qc-8985) into a Risk Register entry, linked to CRA → **Vulnerability Handling** → **1**.

Cross-check with Scan Findings

Security Tools → **Scan Findings** aggregates findings from every scanner (Nmap, ZAP, Semgrep, OSV) into one filterable table. Use it as the single pane of glass before you start the assessment.



CYBERFORT

- Dashboard
- Assessments
- Frameworks
- Assets / Products
- Risks
- Controls
- Documents
- Compliance Chain
- Audit Engagements
- Administration
- Documentation
- AI Assistant
- manastasiadis
- CRA Extended
- Sign out

Scan Findings

Total Findings: 316

Remediated: 0 / 316 (0%)

Linked to Risks: 31 / 316 (10%)

Dependency Scanner: 133
Network Scanner: 16
Code Scanner: 63
Web App Scanner: 104

MEDIUM: 181
HIGH: 12
INFO: 123

Scanner Type: Severity: Risk Link: Remediated: Search title, identi... Reset Refresh

Scanner	Target	Findings	Date
Web App Scanner	https://www.draxis.gr/	11	4/25/2026, 9:10:24 AM
Web App Scanner	https://www.draxis.gr/	11	4/25/2026, 9:10:18 AM
Web App Scanner	https://www.draxis.gr/	11	4/25/2026, 9:10:10 AM
Network Scanner		5	4/25/2026, 9:07:48 AM
Network Scanner	www.draxis.gr/	1	4/25/2026, 9:06:38 AM
Network Scanner	www.draxis.gr/	1	4/25/2026, 9:06:02 AM
Web App Scanner	https://ktelachaias.gr/	10	3/14/2026, 12:39:01 PM

1-50 of 316 findings

After filing all six risks for PortPilot, your **Risk Register** should look similar to this — the new PortPilot entries appear alongside any pre-existing risks for the organisation:

CYBERFORT

Dashboard

Assessments

Frameworks

Assets / Products

Risks

Risk Register

Risk Assessment

Incident Registration

Security Advisories

Controls

Documents

Compliance Chain

Audit Engagements

Administration

Documentation

AI Assistant

manastasiadis

CRA Extended

Sign out

Risk Management

Dashboard

Risk Registry 89

Risk Templates Library 110

Connections

Search risks...

+

 Add New Risk

Export to PDF (89)

Code	Risk Category	Description	Status (Treatment)	Severity	Assessment	Likelihood
RSK-1	DNS Attacks	Attacks targeting Domain Name ...	Accept	Medium	Not Assessed	Medium
RSK-13	Phishing Attacks	Social engineering attacks that tr...	Accept	Medium	Assessment in progress	Low
RSK-30	Accidental fire, water,...	Risk of outages and loss due to ...	Accept	Medium	-	Medium
RSK-31	Availability & Disaste...	Risk of system outage due to a d...	Accept	Medium	-	Medium
RSK-32	Broken or weak auth...	Risk of account hijacking or expl...	Accept	Medium	-	Medium
RSK-33	Brute force attack	Risk of malicious user getting ac...	Accept	Medium	-	Medium
RSK-34	Cancelled contract	A contract is cancelled due to a ...	Accept	Medium	-	Medium
RSK-35	Cloud misconfiguration	Lack of baseline configuration wi...	Accept	Medium	-	Medium
RSK-36	DNS Spoofing	Risk of data theft and malware di...	Accept	Medium	-	Medium
RSK-37	Data breach	Open ports, unrestricted protocol...	Accept	Medium	-	Medium

1-10 of 89 risks

1

2

3

4

5

...

9

10 / page

Step 6 — Complete the CRA conformity assessment

CyberFort ships the **Cyber Resilience Act (CRA)** as a built-in framework. The assessment is a structured questionnaire of conformity questions; you mark each one as **Yes / No / Partially / N/A** and attach evidence.

1. Click **Assessments** in the sidebar. You see your current assessments and a *Create New Assessment* panel on the right.

CYBERFORT

Dashboard

Assessments

Frameworks

Assets / Products

Risks

Controls

Documents

Compliance Chain

Audit Engagements

Administration

Documentation

AI Assistant

manastasiadis

CRA Extended

Sign out

Assessments

Export PDFExport CSVImport CSVSuggest from ScansAI Suggest Answers

Assessment Overview

View your active assessments or create new ones

Active Assessments

1

Assessments currently in progress

pentest

PCI DSS v4.0 • Organization: Clone Systems

0%

Create New Assessment

Start a new assessment for a framework

+ New Assessment

1

Total

0

Completed

Select Assessment

Or browse and select from existing assessments

Framework

Assessment Type

Assessment

CRA

Select type

Select assessment

2. Click **+ New Assessment** and fill the form: * **Framework:** CRA * **Assessment Type:** Conformity * **Scope Type:** Asset / Product * **Asset / Product:** PortPilot * **Assessment Name:** PortPilot CRA Conformity

The screenshot displays the CYBERFORT Assessments dashboard. On the left is a dark sidebar with navigation links: Dashboard, Assessments (active), Frameworks, Assets / Products, Risks, Controls, Documents, Compliance Chain, Audit Engagements, and Administration. At the bottom of the sidebar, the user 'manastasiadis' is logged in with a 'CRA Extended' role and a 'Sign out' button.

The main content area is titled 'Assessments' and includes buttons for 'Export PDF', 'Export CSV', and 'Import C'. A success notification at the top right states 'Assessment Creation Success' and 'Assessment created.'.

The 'Assessment Overview' section prompts the user to 'View your active assessments or create new ones'. It features two main panels:

- Active Assessments:** A green-bordered box containing two assessment cards, both at 0% progress.
 - PortPilot CRA Conformity:** Framework: CRA, Product: PortPilot.
 - pentest:** PCI DSS v4.0, Organization: Clone Systems.
- Create New Assessment:** A blue-bordered box with a form to start a new assessment.
 - Framework: CRA (dropdown)
 - Assessment Type: Conformity (dropdown)
 - Scope Type: Select scope type (dropdown)
 - Assessment Name: Enter assessment name (text input)
 - Buttons: Create, Cancel
 - Summary: 2 Total, 0 Completed

At the bottom, the 'Select Assessment' section allows browsing existing assessments with filters for Framework (CRA), Assessment Type (Conformity), and Assessment (Select assessment).

4. Click the **PortPilot CRA Conformity** card (under *Active Assessments*) — or pick it from the *Select Assessment* dropdown at the bottom. The questionnaire opens with 52 conformity questions, paginated 10 per page.

CYBERFORT

Dashboard

Assessments

Frameworks

Assets / Products

Risks

Controls

Documents

Compliance Chain

Audit Engagements

Administration

Documentation

AI Assistant

manastasiadis

CRA Extended

Sign out

Assessments

Export PDF

Export CSV

Import CSV

Suggest from Scans

AI Suggest Answers

Assessment Overview

View your active assessments or create new ones

Active Assessments2

Assessments currently in progress

PortPilot CRA Conformity

CRA • Product: PortPilot

0%

pentest

PCI DSS v4.0 • Organization: Clone Systems

0%

Create New Assessment

Start a new assessment for a framework

+ New Assessment

2

Total

0

Completed

Select Assessment

Or browse and select from existing assessments

FrameworkCRA

Assessment TypeConformity

AssessmentPortPilot CRA Conformity

Delete Assessment

Assessment Questions

(Asset / Product: PortPilot)

Question 1

Mandatory: YES Completed: NO Common in: CRA(clone-systems.com)

Have you undertaken an assessment of the cybersecurity risks associated with your product with digital elements?

Yes

No

Partially

N/A

Assign PolicyNo Policy

Evidence Description

Describe the evidence supporting this answer...

0 file(s) attached:

Save Answer

Clear Answer

Attach File(s)

Question 2

Mandatory: YES Completed: NO Common in: CRA(clone-systems.com)

Do you take the outcome of the cybersecurity risk assessment into account during the planning, design, development, production, delivery and maintenance phases?

Yes

No

Partially

N/A

Assign PolicyNo Policy

Evidence Description

Describe the evidence supporting this answer...

0 file(s) attached:

Save Answer

Clear Answer

Attach File(s)

Question 3

Mandatory: YES Completed: NO Common in: CRA(clone-systems.com)

Is your cybersecurity risk assessment documented and updated as appropriate during the support period?

Yes

No

Partially

N/A

Assign PolicyNo Policy

Evidence Description

Describe the evidence supporting this answer...

0 file(s) attached:

Save Answer

Clear Answer

Attach File(s)

Question 4

Mandatory: **YES** Completed: **NO** Common in: CRA(clone-systems.com)

Save Answer

Clear Answer

Attach File(s)

Does your cybersecurity risk assessment comprise an analysis based on the intended purpose and reasonably foreseeable use of the product?

☐ Yes ☐ No ☐ Partially ☐ N/A

Assign Policy No Policy

Evidence Description

Describe the evidence supporting this answer...

0 file(s) attached:

Question 5

Mandatory: **YES** Completed: **NO** Common in: CRA(clone-systems.com)

Save Answer

Clear Answer

Attach File(s)

Does your risk assessment take into account the conditions of use, operational environment, and assets to be protected?

☐ Yes ☐ No ☐ Partially ☐ N/A

Assign Policy No Policy

Evidence Description

Describe the evidence supporting this answer...

0 file(s) attached:

Question 6

Mandatory: **YES** Completed: **NO** Common in: CRA(clone-systems.com)

Save Answer

Clear Answer

Attach File(s)

Does your risk assessment consider the length of time the product is expected to be in use?

☐ Yes ☐ No ☐ Partially ☐ N/A

Assign Policy No Policy

Evidence Description

Describe the evidence supporting this answer...

0 file(s) attached:

Question 7

Mandatory: **YES** Completed: **NO** Common in: CRA(clone-systems.com)

Save Answer

Clear Answer

Attach File(s)

Does your cybersecurity risk assessment indicate whether and how the security requirements are applicable to your product?

☐ Yes ☐ No ☐ Partially ☐ N/A

Assign Policy No Policy

Evidence Description

Describe the evidence supporting this answer...

0 file(s) attached:

Question 8

Mandatory: **YES** Completed: **NO** Common in: CRA(clone-systems.com)

Save Answer

Clear Answer

Attach File(s)

Do you include the cybersecurity risk assessment in the technical documentation when placing the product on the market?

☐ Yes ☐ No ☐ Partially ☐ N/A

Assign Policy No Policy

Evidence Description

Describe the evidence supporting this answer...

0 file(s) attached:

Question 9

Mandatory: **YES** Completed: **NO** Common in: CRA(clone-systems.com)

Save Answer

Clear Answer

Attach File(s)

Where certain essential cybersecurity requirements are not applicable, do you include clear justification in the technical documentation?

☐ Yes
☐ No
☐ Partially
☐ N/A

Assign Policy No Policy

Evidence Description

Describe the evidence supporting this answer...

0 file(s) attached:

Question 10

Mandatory: **YES** Completed: **NO** Common in: CRA(clone-systems.com)

Save Answer

Clear Answer

Attach File(s)

Do you systematically document relevant cybersecurity aspects concerning your products with digital elements?

☐ Yes
☐ No
☐ Partially
☐ N/A

Assign Policy No Policy

Evidence Description

Describe the evidence supporting this answer...

0 file(s) attached:

1-10 of 52 questions

1

2

3

4

5

6

5. For each question, choose **Yes / No / Partially / N/A**, add an *Evidence Description*, optionally attach files, then click **Save Answer**. Focus on the eleven below — they are the ones your scan results directly answer. (The number column matches the position you will see in the UI.)

#	Question (read it as it appears in CyberFort)	Your answer	Evidence to attach
13	"Are your products with digital elements delivered without any known exploitable vulnerabilities?"	Not compliant	OSV scan result; ZAP SQLi report
14	"Are your products made available on the market with a secure by default configuration?"	Not compliant	Nmap scan result (port 5432 open); Semgrep <code>flask-debug-true</code>
16	"Do you ensure that vulnerabilities can be addressed through security updates?"	Not compliant	Note that no update channel exists for the container image
20	"Do you ensure protection from unauthorized access by appropriate control mechanisms?"	Not compliant	ZAP SQL-injection report; ZAP broken-access report on <code>/admin/manifests</code>
21	"Do you implement authentication, identity or access management systems?"	Partially compliant	The product has a login form, but SQL injection bypasses it
22	"Do you report on possible unauthorized access?"	Not compliant	App produces no auth-failure logs
23	"Do you protect the confidentiality of stored, transmitted or otherwise processed data through encryption?"	Not compliant	Passwords stored in plaintext (see Postgres <code>users</code> table); <code>/admin/manifests</code> leaks confidential cargo notes

#	Question (read it as it appears in CyberFort)	Your answer	Evidence to attach
25	"Do you protect the integrity of stored, transmitted or otherwise processed data, commands, programs and configuration?"	Not compliant	Semgrep hardcoded-secret finding; reflected XSS allows DOM tampering
32	"Are your products designed, developed and produced to limit attack surfaces, including external interfaces?"	Not compliant	Nmap finding — PostgreSQL exposed on 0.0.0.0:5432
38	"Do you identify and document vulnerabilities and components contained in your products with digital elements?"	Not compliant	No SBOM exists; OSV reveals 4+ unknown advisories
39	"Do you draw up a software bill of materials in a commonly used and machine-readable format?"	Not compliant	No SBOM file ships with the product

6. For every **No** or **Partially** answer, attach the scan output as evidence: click **Attach File(s)** under the question and select the PDF/JSON for that finding. The Evidence Description textarea lets you add a one-line summary that the auditor reads first.

Assessments

Export PDFExport CSVImport CSV

Suggest from ScansAI Suggest Answers

Assessment Overview

View your active assessments or create new ones

Active Assessments2

Assessments currently in progress

PortPilot CRA ConformitySelected

CRA • Product: PortPilot

0%

pentest

PCI DSS v4.0 • Organization: Clone Systems

0%

Create New Assessment

Start a new assessment for a framework

+ New Assessment

2Total

0Completed

Select Assessment

Or browse and select from existing assessments

FrameworkCRA

Assessment TypeConformity

AssessmentPortPilot CRA Conformity

Delete Assessment

Assessment QuestionsAsset / Product: PortPilot

Question 1

Mandatory: YESCompleted: YESCommon in: CRA(clone-systems.com)

Have you undertaken an assessment of the cybersecurity risks associated with your product with digital elements?

Yes

No

Partially

N/A

Assign PolicyNo Policy

Evidence Description

Describe the evidence supporting this answer...

0 file(s) attached:

Save AnswerClear AnswerAttach File(s)

Question 2

Mandatory: YESCompleted: NOCommon in: CRA(clone-systems.com)

Do you take the outcome of the cybersecurity risk assessment into account during the planning, design, development, production, delivery and maintenance phases?

Yes

No

Partially

N/A

Assign PolicyNo Policy

Evidence Description

Describe the evidence supporting this answer...

0 file(s) attached:

Save AnswerClear AnswerAttach File(s)

Question 3

Mandatory: YESCompleted: NOCommon in: CRA(clone-systems.com)

Is your cybersecurity risk assessment documented and updated as appropriate during the support period?

Yes

No

Partially

N/A

Assign PolicyNo Policy

Evidence Description

Describe the evidence supporting this answer...

0 file(s) attached:

Save AnswerClear AnswerAttach File(s)

CYBERFORT

Dashboard

Assessments

Frameworks

Assets / Products

Risks

Controls

Documents

Compliance Chain

Audit Engagements

Administration

Documentation

AI Assistant

manastasiadis

CRA Extended

Sign out

Question 4

Mandatory: **YES** Completed: **NO** Common in: CRA(clone-systems.com)

Does your cybersecurity risk assessment comprise an analysis based on the intended purpose and reasonably foreseeable use of the product?

☐ Yes ☐ No ☐ Partially ☐ N/A

Assign Policy No Policy

Evidence Description

Describe the evidence supporting this answer...

0 file(s) attached:

Save Answer

Clear Answer

Attach File(s)

Question 5

Mandatory: **YES** Completed: **NO** Common in: CRA(clone-systems.com)

Does your risk assessment take into account the conditions of use, operational environment, and assets to be protected?

☐ Yes ☐ No ☐ Partially ☐ N/A

Assign Policy No Policy

Evidence Description

Describe the evidence supporting this answer...

0 file(s) attached:

Save Answer

Clear Answer

Attach File(s)

Question 6

Mandatory: **YES** Completed: **NO** Common in: CRA(clone-systems.com)

Does your risk assessment consider the length of time the product is expected to be in use?

☐ Yes ☐ No ☐ Partially ☐ N/A

Assign Policy No Policy

Evidence Description

Describe the evidence supporting this answer...

0 file(s) attached:

Save Answer

Clear Answer

Attach File(s)

Question 7

Mandatory: **YES** Completed: **NO** Common in: CRA(clone-systems.com)

Does your cybersecurity risk assessment indicate whether and how the security requirements are applicable to your product?

☐ Yes ☐ No ☐ Partially ☐ N/A

Assign Policy No Policy

Evidence Description

Describe the evidence supporting this answer...

0 file(s) attached:

Save Answer

Clear Answer

Attach File(s)

Question 8

Mandatory: **YES** Completed: **NO** Common in: CRA(clone-systems.com)

Do you include the cybersecurity risk assessment in the technical documentation when placing the product on the market?

☐ Yes ☐ No ☐ Partially ☐ N/A

Assign Policy No Policy

Evidence Description

Describe the evidence supporting this answer...

0 file(s) attached:

Save Answer

Clear Answer

Attach File(s)

Question 9

Mandatory: **YES** Completed: **NO** Common in: CRA(clone-systems.com)

Save Answer

Clear Answer

Attach File(s)

Where certain essential cybersecurity requirements are not applicable, do you include clear justification in the technical documentation?

☐ Yes
☐ No
☐ Partially
☐ N/A

Assign Policy No Policy

Evidence Description

Describe the evidence supporting this answer...

0 file(s) attached:

Question 10

Mandatory: **YES** Completed: **NO** Common in: CRA(clone-systems.com)

Save Answer

Clear Answer

Attach File(s)

Do you systematically document relevant cybersecurity aspects concerning your products with digital elements?

☐ Yes
☐ No
☐ Partially
☐ N/A

Assign Policy No Policy

Evidence Description

Describe the evidence supporting this answer...

0 file(s) attached:

1-10 of 52 questions

1

2

3

4

5

6

- Click **Save Answer** on every question. The header for each question flips *Completed* from **NO** to **YES** once a valid answer is saved.

 The toolbar at the top of the Assessments page has a **Suggest from Scans** button and an **AI Suggest Answers** button — both pre-populate likely answers based on the scan findings you filed in steps 2-5. Use them on at least two questions: it is one of the platform features you are demonstrating.

 If you also want to fill in the **organisational audit questions** (the 95-question audit set on the same CRA framework), you can — but it is not required for this scenario. The conformity assessment is the product-level one CRA Article 32 requires before placing the product on the market.

Step 7 — Generate the CRA readiness report

- Stay on the **Assessments** page with **PortPilot CRA Conformity** selected.
- Use the top-right toolbar: * **Export PDF** — produces a PDF of the answered conformity questionnaire with evidence references. * **Export CSV** — exports the answers as CSV (handy for the auditor's working spreadsheet).
- From the **Risks** sidebar, you can also click **Export PDF** on the Risk Register dashboard to attach the full risk export to the readiness pack.

The combined PDFs (Conformity + Risk Register) form the **CRA readiness deliverable** you hand to your instructor — and the same documents an SME would attach to its Article 28 *EU Declaration of Conformity* technical documentation.

Step 8 — Stretch goals (optional)

If you finish early, try the following:

- Patch one of the vulnerabilities (your instructor has the patch set) and rerun the relevant scan to verify it is now clean.
 - Use the **Policy** module to draft a *Secure Development Lifecycle* policy and link it to CRA → Vulnerability Handling → objective **3** (*effective and regular security tests*).
 - Use Nmap's `-sV` profile to identify the exact Postgres and Python versions running.
-

Checklist

Tick these off before declaring the scenario complete.

- ☐ PortPilot registered as a product
- ☐ Nmap scan completed; 5432 risk filed
- ☐ ZAP scan completed; SQLi, XSS, broken-access risks filed
- ☐ Semgrep scan completed; hardcoded-secret risk filed
- ☐ OSV scan completed; at least one transitive-dep risk filed
- ☐ CRA assessment answered against Annex I
- ☐ PDF readiness report generated and exported